

Kiến trúc CRM Luật Vũ Khang

Chọn nền tảng mã nguồn mở, mô hình dữ liệu hồ sơ vụ việc, kho tài liệu hai chiều và các luồng nghiệp vụ chuẩn — đủ chi tiết để giao thẳng cho lập trình viên triển khai.

NỀN TẢNG LARAVEL 13 + FILAMENT 5 HẠ TẦNG PHP 8.3 / MARIADB NGÀY 13.09.2026

KẾT LUẬN

Xây riêng trên Laravel, không uốn một CRM bán hàng

Không có CRM mã nguồn mở nào được viết cho nghề luật. Mọi lựa chọn đều là CRM bán hàng, và uốn một CRM bán hàng thành hệ quản lý hồ sơ vụ việc tốn công hơn là xây riêng phần nghiệp vụ trên một nền Laravel sạch. Quyết định: **Laravel 13 + Filament 5**, trong đó Filament lo phần khó và nguy hiểm — xác thực, phân quyền, giao diện quản trị, và đặc biệt là **hai panel trong một ứng dụng** để panel nội bộ và portal khách hàng dùng chung mã nguồn nhưng tách hoàn toàn về quyền.

Hai panel, một codebase

PHP 8.3+

Chạy được shared hosting

Không vướng AGPL

Mã nguồn thuộc công ty

Tự chịu trách nhiệm bảo trì

01

Vì sao xây riêng, và vì sao không fork một CRM có sẵn

Trước khi chốt xây riêng, đây là kết quả rà soát toàn bộ nhóm CRM mã nguồn mở phổ biến. Số sao GitHub không phải tiêu chí — chỉ có bốn câu hỏi quyết định, và chúng loại gần hết ứng viên ngay từ vòng đầu.

MÃ NGUỒN	PORTAL CHO KHÁCH CÓ SẴN, MIỄN PHÍ	CHẠY SHARED HOSTING PHP	THÊM ENTITY MỚI KHÔNG ĐỤNG CORE	BẢO TRÌ 2026	KẾT LUẬN
EspoCRM	Có	Có	Entity Manager	Rất tích cực	Ứng viên mạnh nhất, nhưng vướng AGPLv3 và Advanced Pack trả phí
Odoo 18	Có	Không — cần VPS	Studio (trả phí)	Tích cực	Chỉ khi nâng lên VPS và cần cả kế toán
ERPNext / Frappe CRM	Có	Không — Python, Redis	DocType	Tích cực	Quá nặng cho một văn phòng luật
Krayin (Laravel)	Không có	Có	Phải code package	Tích cực	Phải tự viết portal — thêm 2-3 tháng
Twenty	Không có	Không — Node + Postgres	Rất tốt	Rất tích cực	Đẹp nhưng sai hạ tầng và thiếu portal
SuiteCRM 8	Module riêng, cài khó	Có	Studio, code cũ	Chậm	Nợ kỹ thuật lớn
Vtiger 7 Open Source	Có nhưng lỗi thời	Có	Hạn chế	Gần như dừng	Không nên đầu tư mới
Dolibarr	Cần module bên thứ ba	Có	Phải code module	Tích cực	Thiên về ERP nhỏ, portal yếu

Ràng buộc hạ tầng đã loại một nửa danh sách

Website công ty đang nằm trên shared hosting phổ thông, và đúng vấn đề đã gặp trước đây — một ứng dụng Node.js không chạy được vì hosting không có môi trường phù hợp — sẽ lặp lại y hệt với Twenty, và còn nặng hơn với Odoo hay ERPNext. Mọi thứ chạy Python hoặc Node đều cần VPS. Vì vậy nền tảng phải là PHP.

CẦN XÁC MINH TRƯỚC KHI CÀI

Hỏi nhà cung cấp hosting đúng bốn điểm: **PHP ≥ 8.3, MariaDB ≥ 10.3 hoặc MySQL ≥ 8.0, cho phép cron chạy mỗi phút, và tạo được subdomain riêng.** Thiếu cron thì toàn bộ nhắc hạn tố tụng và email tự động ở mục 09 sẽ không hoạt động — đây là điểm chết người nhiều nơi bỏ qua.

Nếu hosting không đáp ứng: một VPS 2 vCPU / 4 GB RAM tại Việt Nam chi phí khoảng 200–300 nghìn đồng/tháng là dư dùng cho 10–20 người, và mở đường sang Odoo sau này nếu công ty lớn lên.

Kết luận: lấy nền, không lấy sản phẩm

Bảng trên cho thấy hai lựa chọn duy nhất có portal sẵn và chạy được PHP hosting đều có vấn đề riêng: EspoCRM vướng giấy phép AGPLv3 và cần mua Advanced Pack mới có trình thiết kế workflow, SuiteCRM thì nợ kỹ thuật quá lớn. Còn Krayin và Twenty đều **không có portal khách hàng** — mà portal chính là lý do làm hệ thống này.

Nên hướng đi là: **lấy thư viện, không lấy sản phẩm.** Toàn bộ phần khó và nguy hiểm — xác thực, phân quyền, lưu tệp, nhật ký hệ thống, sao lưu — dùng các gói Laravel đã được cộng đồng kiểm chứng nhiều năm. Phần nghiệp vụ riêng của văn phòng luật thì tự viết, vì không repo nào viết sẵn đúng cả.

LỚP	DÙNG GÌ	VÌ SAO KHÔNG TỰ VIẾT
Framework	Laravel 13, PHP 8.3+	—
Giao diện quản trị và portal	Filament 5	Hỗ trợ nhiều panel trong một ứng dụng, mỗi panel một guard riêng
Vai trò và quyền	spatie/laravel-permission	Tự viết bảng roles là nguồn lỗi hỏng phân quyền kinh điển
Tệp đính kèm	spatie/laravel-medialibrary	Đã xử lý sẵn disk private, tên tệp ngẫu nhiên, kiểm tra MIME
Nhật ký hệ thống	spatie/laravel-activitylog	Bắt buộc với hồ sơ pháp lý, và rất dễ viết thiếu
Sao lưu	spatie/laravel-backup	Sao lưu ra ngoài máy chủ theo lịch
Xác thực hai lớp	laravel/fortify	Không bao giờ tự cài đặt TOTP

CÁI GIÁ CỦA VIỆC XÂY RIÊNG

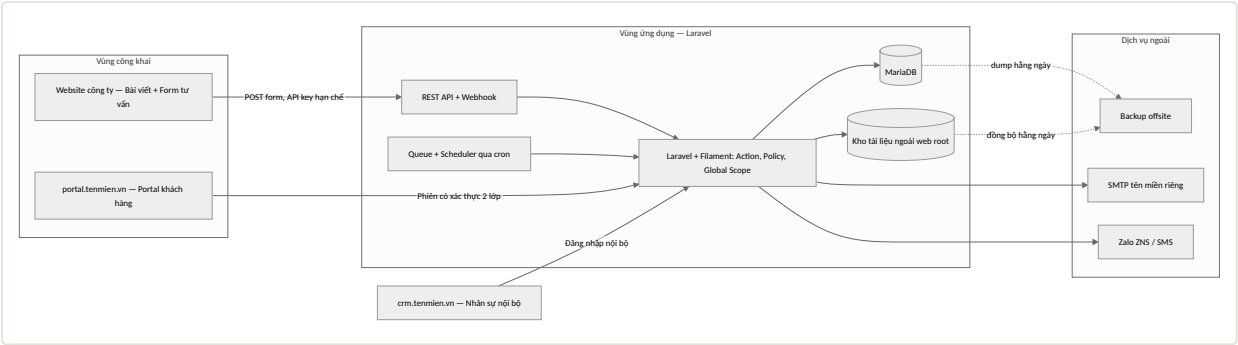
Nói cho sòng phẳng: đổi lại sự vừa vặn, công ty **tự chịu trách nhiệm bảo trì**. Không có cộng đồng vá lỗi, không có bản nâng cấp sẵn. Bù lại mã nguồn hoàn toàn thuộc về công ty, không vướng AGPL, và sau này đóng gói bán cho văn phòng luật khác được.

Điều kiện để đánh đổi này an toàn: **mọi quy tắc bảo mật đều phải có một bài kiểm thử tự động đi kèm**. Không có test thì không có cách nào biết một lần sửa code về sau đã phá vỡ ranh giới dữ liệu giữa các khách hàng.

02

Kiến trúc tổng thể

Nguyên tắc xuyên suốt: **website giới thiệu, CRM nội bộ và portal khách hàng là ba vùng tách biệt**, chạy trên ba subdomain khác nhau, dù portal và CRM dùng chung một ứng dụng Laravel. Tách domain cho phép đặt tường lửa, giới hạn IP và chính sách cookie khác nhau cho từng vùng.



HÌNH 1 · SƠ ĐỒ THÀNH PHẦN VÀ ĐƯỜNG DỮ LIỆU

VÌ SAO PORTAL TÁCH DOMAIN RIÊNG

- **Giảm bề mặt tấn công.** `crm.` có thể chặn theo dải IP văn phòng hoặc bắt buộc VPN; `portal.` mở ra Internet nhưng chỉ phục vụ một tập API rất hẹp.
- **Tách cookie và phiên.** Phiên của khách hàng không bao giờ dùng chung không gian cookie với phiên luật sư.

- **Thương hiệu.** Portal mang giao diện và logo của công ty, khách hàng không thấy giao diện quản trị.

KHO TÀI LIỆU ĐẶT NGOÀI WEB ROOT

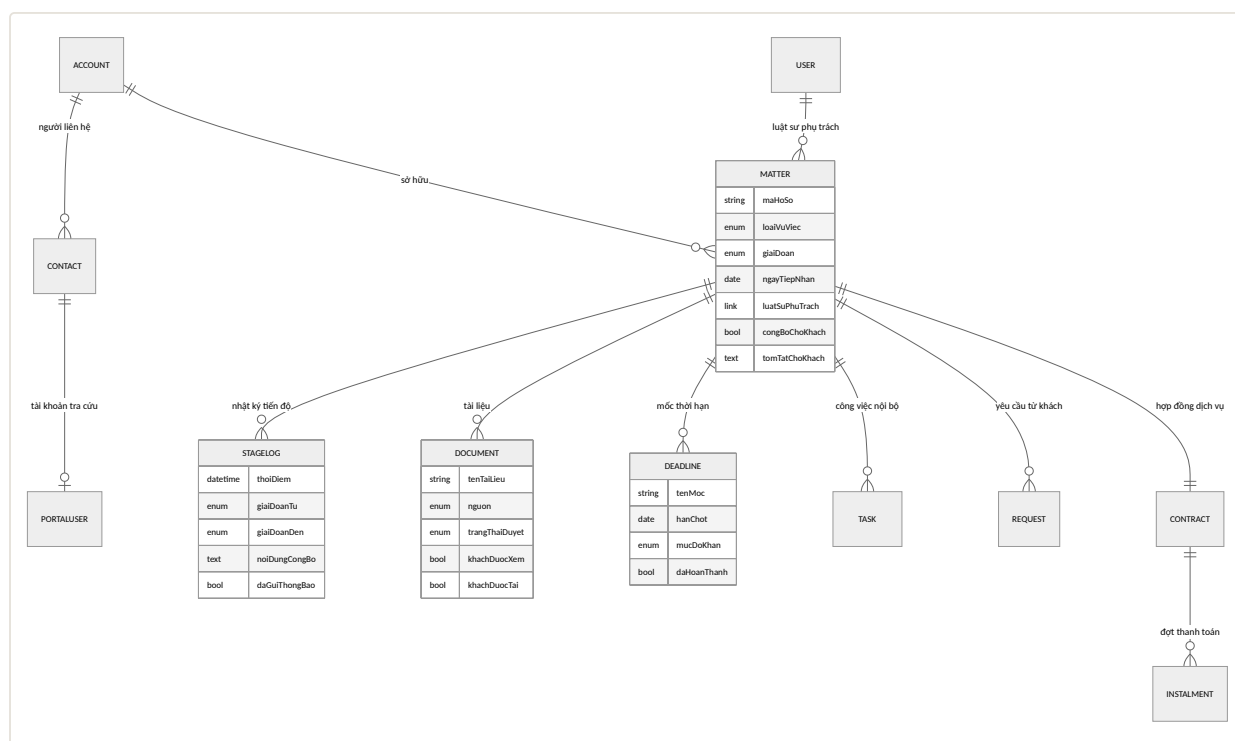
Đây là chi tiết hay bị làm sai nhất. File hồ sơ vụ việc — sổ đỏ, hợp đồng, bản án — **không được** nằm trong thư mục web truy cập trực tiếp bằng URL. Tập lưu ở

`storage/app/private/` với tên sinh ngẫu nhiên, phục vụ qua controller có kiểm tra quyền và ghi log từng lượt tải. Phải chặn truy cập trực tiếp vào thư mục này ở tầng web server.

03

Mô hình dữ liệu hồ sơ vụ việc

CRM bán hàng thông thường dừng ở Khách hàng — Cơ hội — Hợp đồng. Văn phòng luật cần thêm một trục nữa: **Vụ việc** là thực thể trung tâm, mọi thứ khác treo vào nó. Toàn bộ bảng dưới đây là migration Laravel, mỗi bảng có một Filament resource tương ứng.



HÌNH 2 · SƠ ĐỒ QUAN HỆ THỰC THỂ, RÚT GỌN Ở CÁC TRƯỜNG QUYẾT ĐỊNH HÀNH VI HỆ THỐNG

Ba trường điều khiển toàn bộ portal

Đây là phần thiết kế quan trọng nhất và cũng là phần phân biệt một hệ thống làm cẩn thận với một hệ thống làm ẩu:

- `MATTER.congBoChoKhach` — công tắc tổng. Tắt thì vụ việc hoàn toàn vô hình trên portal, dù khách có đúng quyền.
- `STAGELOG.noiDungCongBo` — **tách bạch ghi chú nội bộ và nội dung công bố**. Luật sư ghi nhận định chuyên môn ở trường nội bộ; trường công bố mới là thứ khách đọc. Không bao giờ để khách đọc trực tiếp ghi chú nội bộ.
- `DOCUMENT.khachDuocXem` và `khachDuocTai` — hai quyền tách riêng. Có tài liệu cho khách biết là đã có, nhưng chưa cho tải về.

QUY TẮC MÃ HỒ SƠ

Đặt mã theo dạng `VK - [năm] - [loại] - [số thứ tự]`, ví dụ `VK - 2026 - DD - 0147` cho vụ đất đai thứ 147 của năm. Sinh tự động trong transaction có khoá để tránh trùng khi hai người tạo cùng lúc. Mã này đồng thời là **nội dung chuyển khoản** ở luồng thu phí (mục 10), giúp đối chiếu sao kê ngân hàng gần như tự động.

Các bên trong vụ việc, và lý do thật sự của bảng này

Ngoài khách hàng, mỗi vụ việc còn có nguyên đơn, bị đơn, người có quyền lợi nghĩa vụ liên quan. Nhiều hệ thống bỏ qua vì tưởng là dữ liệu phụ. Thực ra bảng này tồn tại vì **một lý do duy nhất nhưng không thể thiếu với nghề luật: kiểm tra xung đột lợi ích**.

Không có nó thì không có cách nào biết văn phòng đã từng nhận bảo vệ cho chính bên đối lập trong một vụ khác. Mỗi bên lưu tên, số điện thoại đã chuẩn hoá, và **mã băm SHA-256 của số căn cước** — băm chứ không lưu số, để đối chiếu trùng mà không nhân bản dữ liệu định danh ra thêm một chỗ nữa.

QUY TẮC KIỂM TRA XUNG ĐỘT

Chạy bắt buộc trước khi lưu vụ việc mới và mỗi lần thêm một bên. Ba mức: **đỏ** khi bên đối lập đang là khách hàng hiện hữu — chặn, chỉ trưởng phòng ghi đề được và phải nhập lý do; **vàng** khi từng xuất hiện ở hồ sơ khác — cho lưu nhưng bắt xác nhận đã xem xét; **xanh** khi không trùng.

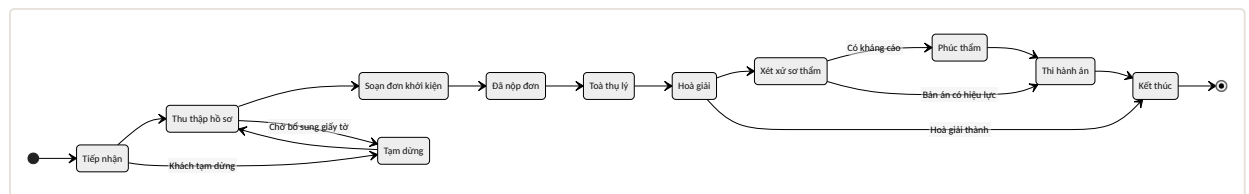
Một ngoại lệ có chủ đích của quy tắc phân quyền: kết quả kiểm tra hiện **mã hồ sơ và vai của bên đó, nhưng không hiện nội dung hay tài liệu** của hồ sơ mà người dùng không có quyền. Đủ để nhận ra xung đột, không đủ để lộ bí mật hồ sơ khác. Và mọi lần chạy đều ghi nhật ký, kể cả khi kết quả xanh — phải chứng minh được là đã kiểm tra.

04

Vòng đời vụ việc

Giai đoạn phải là một máy trạng thái có ràng buộc, không phải một danh sách thả tự do.

Ràng buộc chuyển trạng thái là thứ khiến dữ liệu sạch sau hai năm vận hành. Sơ đồ dưới là mẫu cho tranh tụng dân sự — mỗi loại vụ việc nên có một tập giai đoạn riêng.



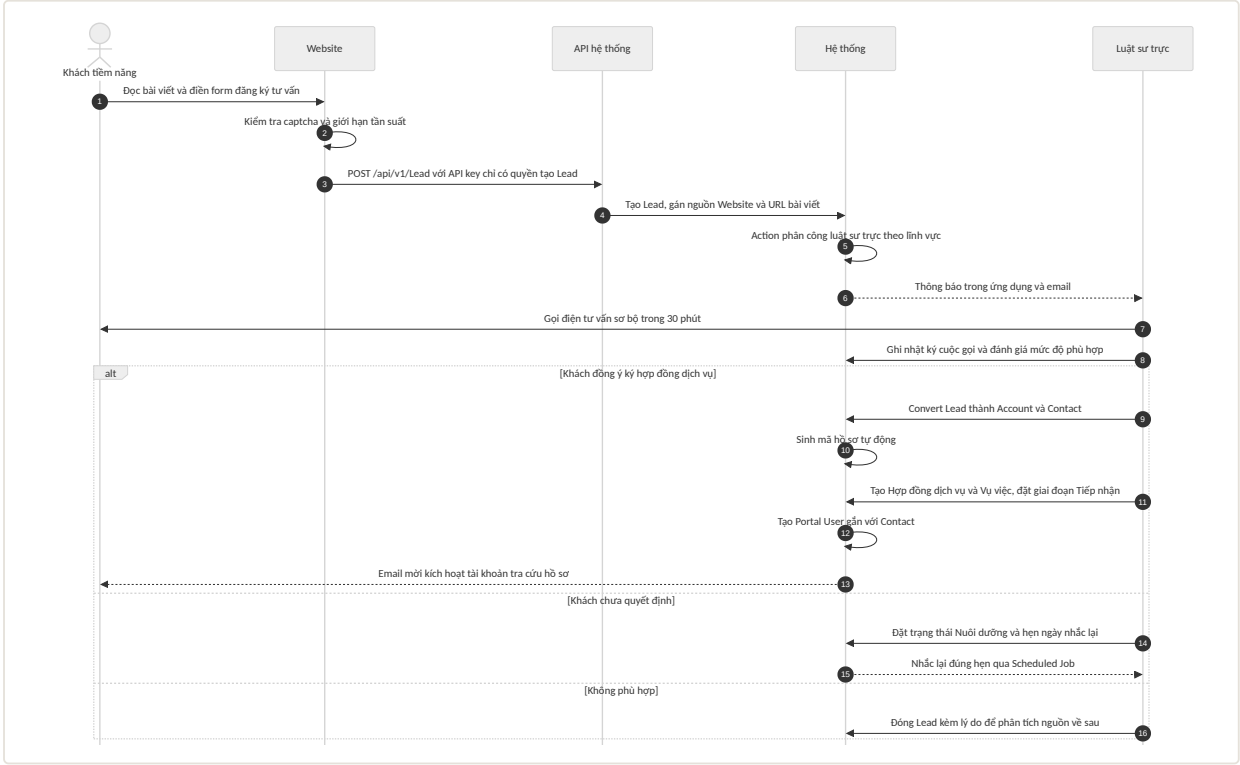
HÌNH 3 · MÁY TRẠNG THÁI GIAI ĐOẠN TÔ TỰNG, MẪU CHO TRANH CHẤP DÂN SỰ

Mỗi lần chuyển trạng thái, hệ thống bắt buộc sinh một bản ghi `STAGEL0G`. Không cho phép sửa lịch sử — chỉ thêm dòng mới. Dòng thời gian mà khách nhìn thấy trên portal chính là chuỗi `STAGEL0G` đã được đánh dấu công bố, nên nó luôn khớp với thực tế hồ sơ và không ai phải cập nhật thủ công ở hai nơi.

05

Luồng 1 — Từ khách truy cập website đến mở hồ sơ

Đây là điểm nối giữa công sức SEO trên website và hệ thống. Mọi form tư vấn trên website công ty phải đổ thẳng vào CRM, không đi qua email — email làm mất dấu vết và không đo được tỉ lệ chuyển đổi.



HÌNH 4 · LƯỒNG TIẾP NHẬN KHÁCH HÀNG, TỪ FORM WEBSITE ĐẾN TÀI KHOẢN PORTAL

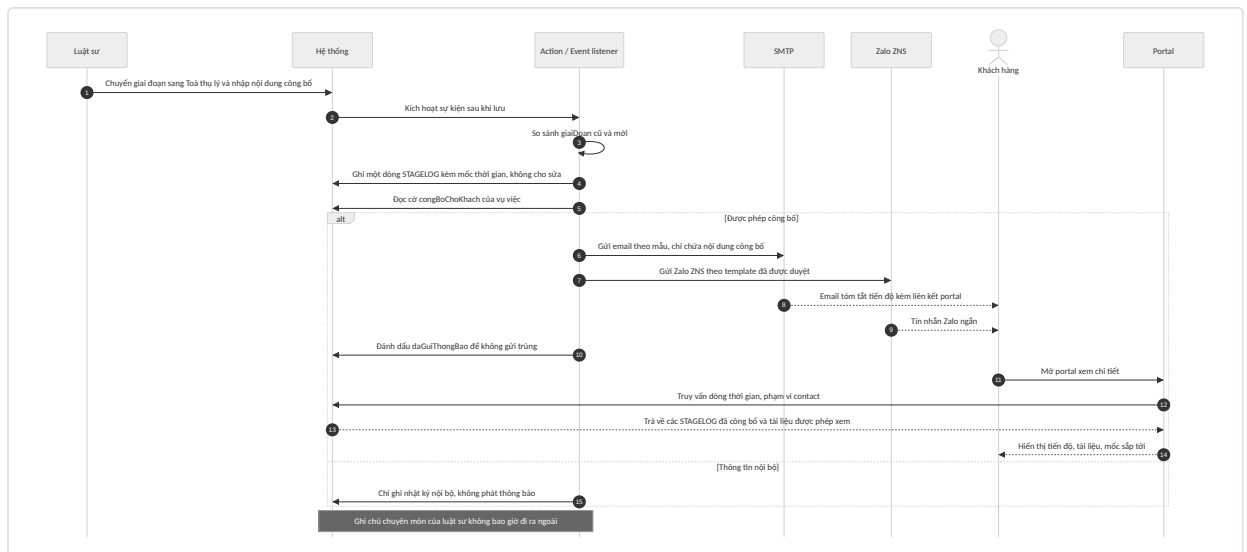
BẢO MẬT API KEY CỦA WEBSITE

Tạo một API token riêng, gán quyền **chỉ được tạo bản ghi Lead**, không có quyền đọc. Nếu key bị lộ, kẻ tấn công chỉ có thể tạo lead rác — không đọc được một dòng dữ liệu khách hàng nào. Đặt key ở phía server của website, tuyệt đối không nhúng vào JavaScript.

06

Luồng 2 — Cập nhật tiến độ và thông báo khách hàng

Luồng quan trọng nhất của toàn hệ thống, và cũng là lý do anh muốn xây nó. Nguyên tắc thiết kế: **luật sư chỉ làm một thao tác duy nhất** — chuyển giai đoạn. Mọi việc còn lại do hệ thống lo. Nếu bắt luật sư vừa đổi giai đoạn, vừa soạn email, vừa nhắn Zalo thì sau ba tháng sẽ không ai dùng nữa.



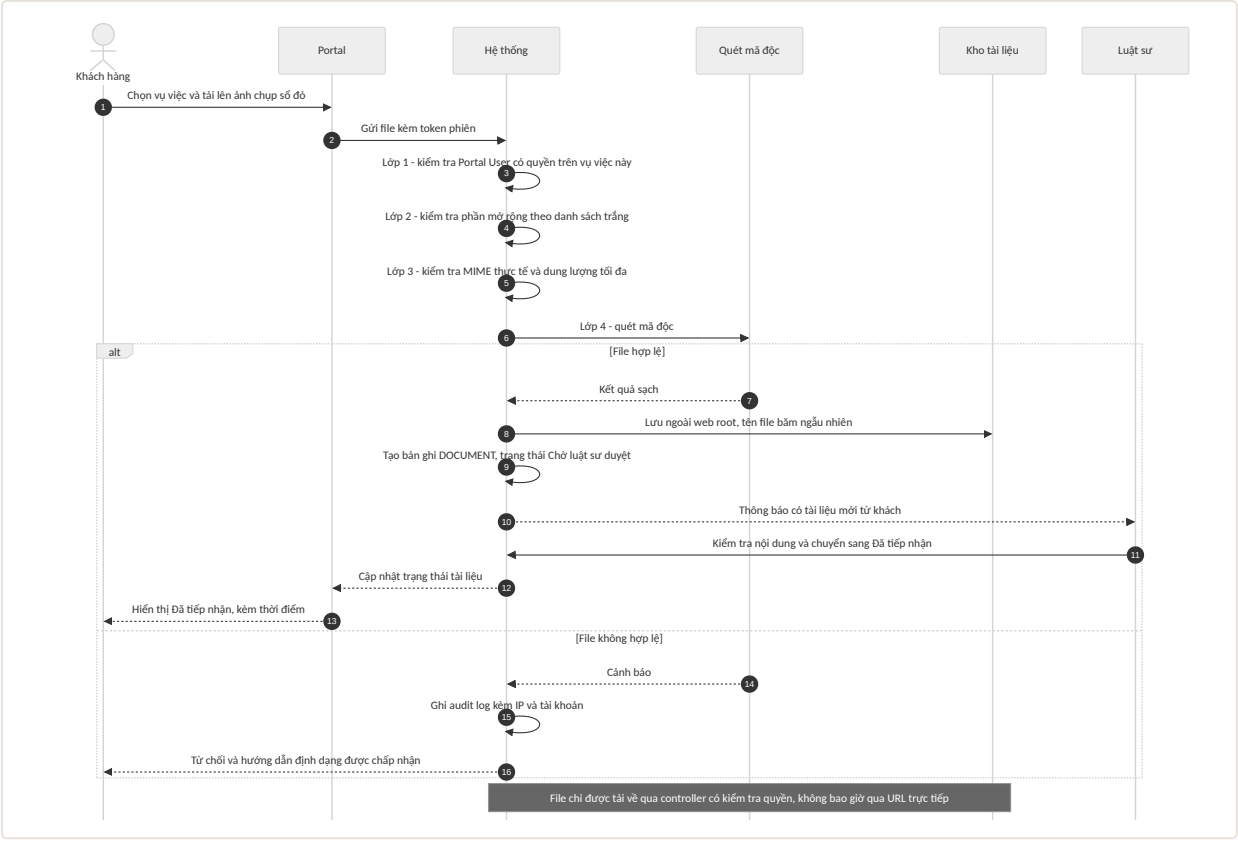
HÌNH 5 · MỘT THAO TÁC CỦA LUẬT SƯ SINH RA TOÀN BỘ CHUỖI THÔNG BÁO

CHI TIẾT DỄ Ỗ SÓT

- **Chống gửi trùng.** Cờ `đãGửiThôngBao` trên từng dòng STAGELOG là bắt buộc — nếu không, một lần lưu lại bản ghi sẽ bắn email lần hai cho khách.
- **Zalo ZNS cần template duyệt trước.** Zalo không cho gửi tin tự do; phải đăng ký mẫu tin và chờ duyệt. Thiết kế mẫu tin ngắn, không chứa thông tin nhạy cảm, chỉ dẫn khách bấm vào portal để xem chi tiết.
- **Email phải gửi qua SMTP tên miền riêng** có SPF, DKIM, DMARC. Gửi từ Gmail cá nhân sẽ vào spam và làm hỏng uy tín tên miền website.

07 Luồng 3 — Khách hàng tải tài liệu lên

Cho phép người ngoài upload file vào hệ thống là chỗ rủi ro bảo mật cao nhất. Luồng dưới đây có bốn lớp kiểm tra trước khi file chạm vào đĩa.



HÌNH 6 · BÔN LỚP KIỂM TRA TRƯỚC KHI TÀI LIỆU CỦA KHÁCH ĐƯỢC LƯU

Danh sách trắng nên hẹp: pdf , jpg , png , docx , xlsx . Giới hạn 20 MB mỗi file.
Tuyệt đối không chấp nhận zip , rar , html , svg — SVG có thể chứa JavaScript và là vector tấn công XSS kinh điển.

08 Kho tài liệu hai chiều

Tài liệu là thứ khách hàng chạm vào nhiều nhất trên portal, và cũng là phần mang rủi ro cao nhất của cả hệ thống. Kho tài liệu chạy hai chiều: **khách nộp lên** giấy tờ gốc, và **luật sư phát hành xuống** các văn bản đã soạn. Hai chiều này có quy tắc hoàn toàn khác nhau và không được trộn lẫn.

Bốn nhóm tài liệu và quyền mặc định

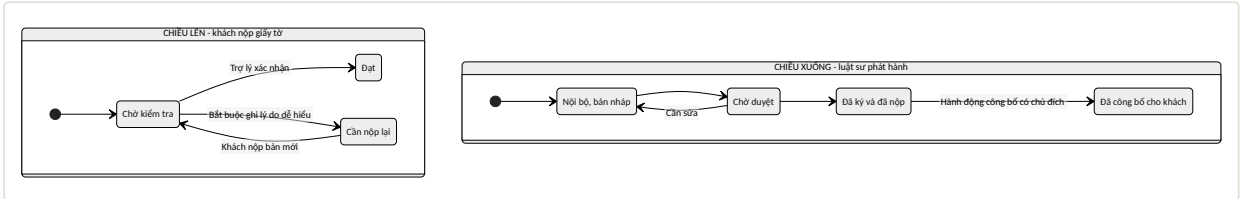
NHÓM	VÍ DỤ	KHÁCH XEM	KHÁCH TẢI	NGUYÊN TẮC
A · Khách cung cấp	Căn cước, sổ đo, hợp đồng gốc, ảnh hiện trạng	Có	Có	Tài liệu của chính họ, luôn xem lại được
B · Văn bản đã phát hành	Đơn khởi kiện đã nộp có dấu, công văn đã gửi, bản tự khai	Có	Có	Chỉ công bố sau khi đã nộp hoặc gửi thật
C · Văn bản từ cơ quan nhà nước	Thông báo thụ lý, quyết định, biên bản, bản án	Có	Có	Đăng trong 24 giờ kể từ khi nhận được
D · Hồ sơ công việc nội bộ	Bản nháp, memo phân tích, phương án tranh tụng, ghi chú chuyên môn	Không bao giờ	Không	Không có nút bật công bố trên giao diện thường

Nguyên tắc cứng: mặc định là ẩn. Mọi tài liệu sinh ra trong hệ thống đều bắt đầu ở trạng thái nội bộ. Phải có một hành động có chủ đích mới công bố được — không bao giờ thiết kế theo chiều ngược lại, kiểu mặc định hiện rồi ai muốn giấu thì tự tắt.

RỦI RO THẬT CỦA MODULE NÀY

Không phải hacker, mà là **một ô tích nhầm**. Một bản nháp đơn khởi kiện lọt ra portal — khách đọc được lập luận chưa hoàn thiện, phương án dự phòng, hay đánh giá điểm yếu của chính hồ sơ mình — là mất niềm tin ngay lập tức. Nặng hơn, nếu khách chia sẻ ra ngoài thì đó là phương án tranh tụng bị lộ cho bên đối lập.

Vì vậy Nhóm D phải được chặn ở **tầng kiến trúc, không phải ở tầng giao diện**: chặn bằng global scope áp trên guard khách hàng, để truy vấn từ portal không bao giờ chạm tới nhóm này, thay vì chỉ dựa vào một checkbox mà người một mỗi lúc 10 giờ đêm có thể bấm nhầm.

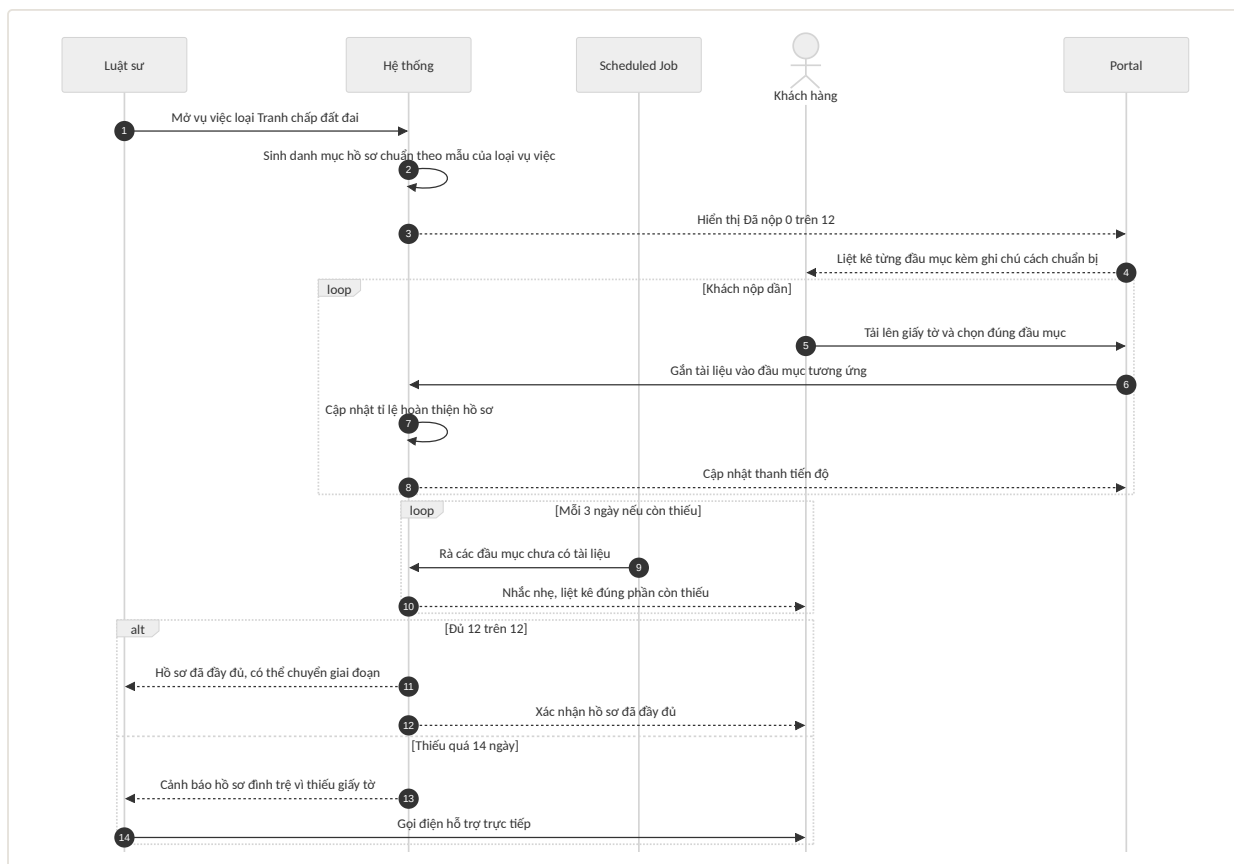


HÌNH 7 · VÒNG ĐỜI TÀI LIỆU, HAI CHIỀU TÁCH BẠCH

Chú ý cạnh **D3 → D4** : văn bản chỉ ra tới khách **sau khi đã ký và đã nộp**, không phải sau khi soạn xong. Ràng buộc này ngăn đúng tình huống nguy hiểm nhất — khách nhìn thấy một bản đơn mà toà chưa hề nhận được.

Danh mục hồ sơ chuẩn — phần trả lời câu hỏi “hồ sơ tôi tới đâu” bằng con số

Đây là tính năng em cho là có sức nặng nhất với khách hàng, và hầu như không văn phòng luật nào ở Việt Nam đang làm. Mỗi loại vụ việc có một danh mục giấy tờ chuẩn. Khi mở hồ sơ, hệ thống tự sinh danh mục đó. Portal hiển thị cho khách một con số rất cụ thể: **Đã nộp 7 trên 12**, kèm đúng tên những thứ còn thiếu.



HÌNH 8 · DANH MỤC HỒ SƠ CHUẨN VÀ VÒNG NHẮC BỒ SUNG TỰ ĐỘNG

Ba cái lợi, theo thứ tự quan trọng:

- **Trả lời câu hỏi của khách bằng con số thay vì bằng cảm giác.** “Hồ sơ anh đã đủ 9 trên 12, còn thiếu biên bản hoà giải, trích lục địa chính và ảnh hiện trạng” là câu trả lời mà khách gác máy xong thấy yên tâm.
- **Chuyển việc đòi giấy tờ từ người sang hệ thống.** Trợ lý không phải gọi nhắc năm lần; portal nhắc thay, lịch sự và đều đặn.
- **Nhìn ra hồ sơ đang tắc.** Ban lãnh đạo thấy ngay những vụ đứng yên vì khách chưa nộp giấy tờ — loại đình trệ mà trước đây chỉ phát hiện khi đã muộn.

VÍ DỤ DANH MỤC CHO TRANH CHẤP ĐẤT ĐAI

Mẫu dưới đây để hình dung cấu trúc; văn phòng nên tự chuẩn hoá lại theo thực tiễn xét xử và quy định hiện hành, rồi lưu thành mẫu dùng chung.

1. Giấy tờ tùy thân của người khởi kiện, bản sao chứng thực **bắt buộc**
2. Giấy chứng nhận quyền sử dụng đất hoặc giấy tờ về quyền sử dụng đất **bắt buộc**
3. Biên bản hoà giải tại Ủy ban nhân dân cấp xã **bắt buộc**
4. Hợp đồng chuyển nhượng, tặng cho, hoặc văn bản về thừa kế liên quan
5. Trích lục bản đồ địa chính, trích đo thửa đất
6. Văn bản, quyết định của cơ quan nhà nước liên quan đến thửa đất
7. Chứng cứ về quá trình sử dụng đất, ví dụ biên lai thuế, hoá đơn điện nước
8. Ảnh hiện trạng thửa đất và công trình trên đất
9. Danh sách, địa chỉ người có quyền lợi và nghĩa vụ liên quan

- 10. Hợp đồng dịch vụ pháp lý và giấy uỷ quyền bắt buộc
- 11. Giấy chứng tử và văn bản kê khai di sản, nếu có yếu tố thừa kế
- 12. Tài liệu khác theo yêu cầu của toà án

Lý do từ chối phải viết cho người thường đọc

Khi trợ lý đánh dấu một giấy tờ là Cần nộp lại, hệ thống bắt buộc nhập lý do, và lý do đó hiện thẳng trên portal. Đây là chi tiết nhỏ nhưng quyết định cảm nhận về chất lượng dịch vụ:

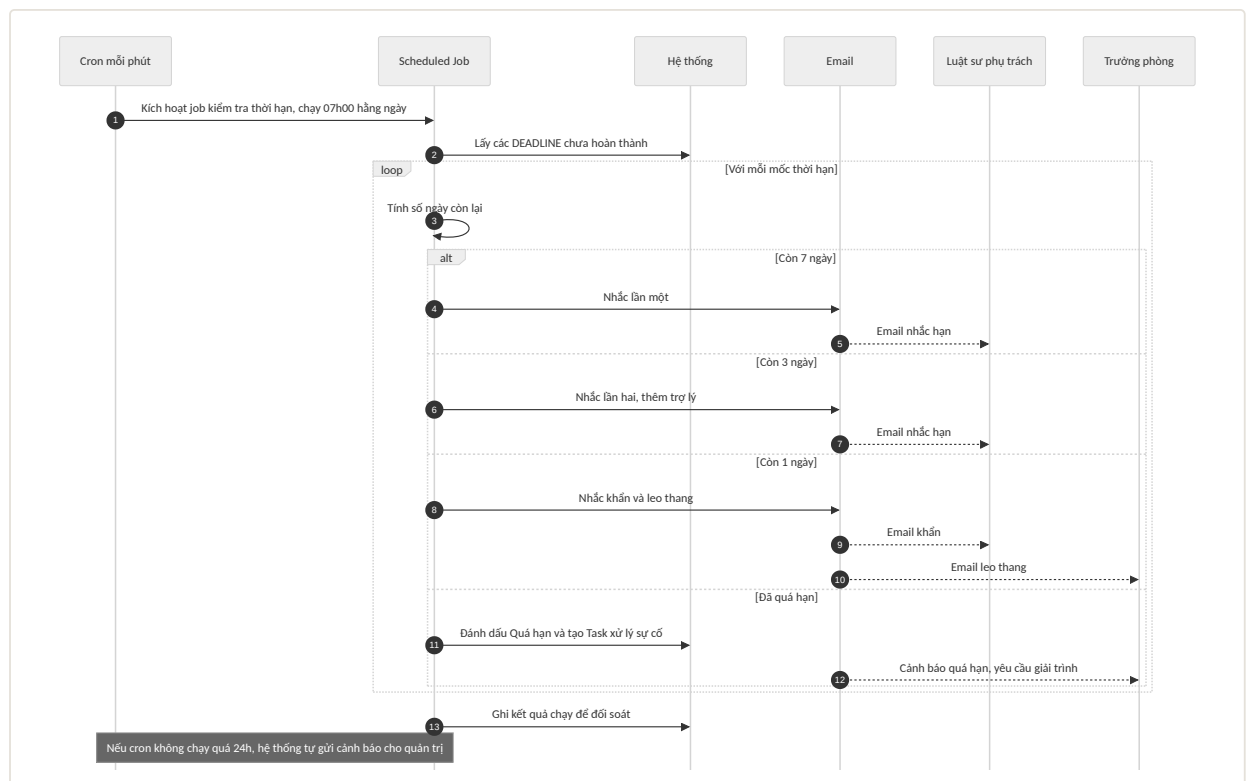
CÁCH VIẾT KÉM	CÁCH VIẾT NÊN DÙNG
Không hợp lệ	Ảnh bị mờ ở góc trên nên không đọc được số thửa. Nhờ anh chị chụp lại dưới ánh sáng tự nhiên, lấy trọn cả bốn góc trang.
Thiếu chứng thực	Bản này là bản photo chưa chứng thực. Toà yêu cầu bản sao có chứng thực, anh chị mang bản gốc ra Uỷ ban phường hoặc phòng công chứng để chứng thực giúp em.
Sai tài liệu	File này là sổ hộ khẩu, còn mục đang cần là giấy chứng nhận quyền sử dụng đất. Anh chị kiểm tra lại giúp em nhé.

VÀI QUY ƯỚC KỸ THUẬT NÊN CHỚT SỚM

- **Quy tắc đặt tên hiển thị:** [Mã hồ`sơ] - [Tên đầu mục] - [Ngày] , để khách tải về máy vẫn biết file của vụ nào.
- **Đánh phiên bản, không ghi đè.** Khách nộp lại lần hai thì lưu thành bản mới, giữ nguyên bản cũ. Sau này cần chứng minh khách đã nộp gì, lúc nào, sẽ có đủ dấu vết.
- **Ghi log mọi lượt tải về.** Ai tải, tài liệu nào, lúc nào, từ địa chỉ nào — vừa phục vụ đối soát, vừa là căn cứ nếu có tranh chấp về việc đã cung cấp tài liệu hay chưa.
- **Xem trước trong trình duyệt trước khi cho tải.** Với một số văn bản nhạy cảm, chỉ cho xem dạng ảnh có đóng dấu mờ tên khách hàng, hạn chế việc phát tán lại.

Luồng 4 — Cảnh báo hạn tố tụng

Với nghề luật, đây là chức năng có giá trị lớn nhất về mặt quản trị rủi ro. Quá hạn kháng cáo hay hạn nộp bổ sung chứng cứ không chỉ mất vụ việc mà còn là rủi ro trách nhiệm nghề nghiệp. Cơ chế leo thang nhiều nấc bên dưới bảo đảm không có mốc nào rơi vào im lặng.

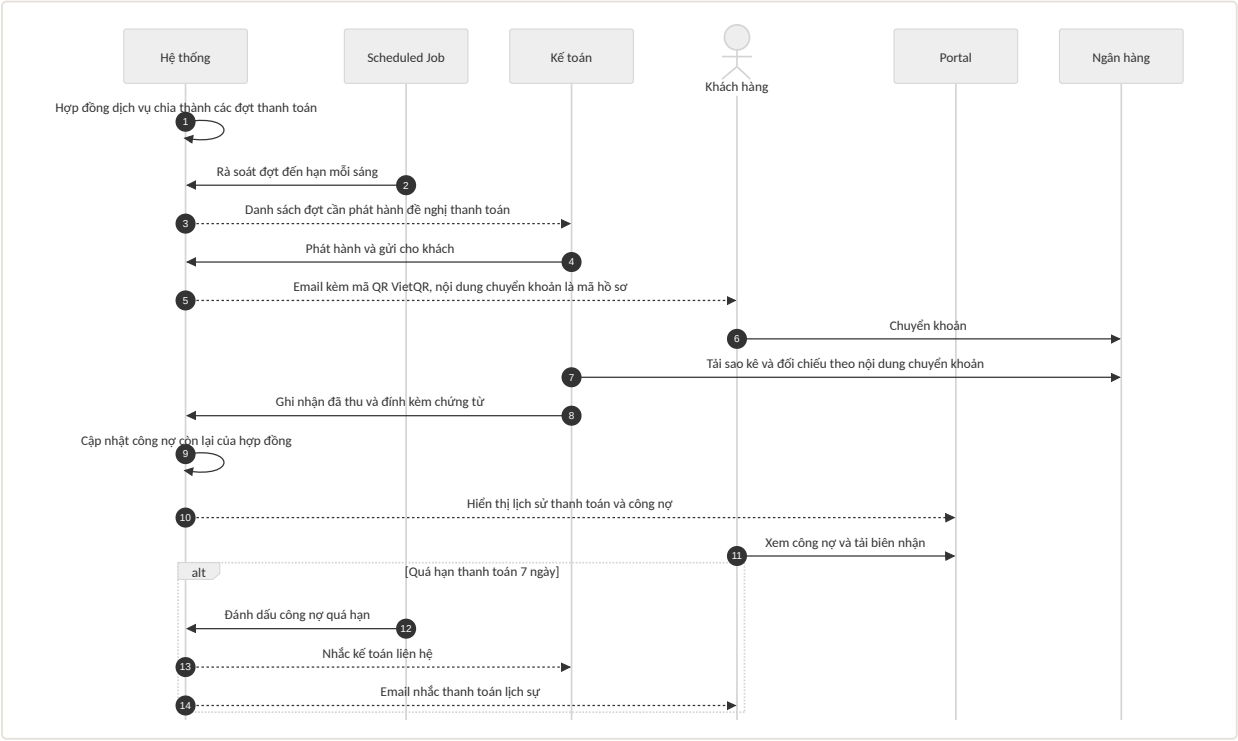


HÌNH 9 · NHẮC HẠN NHIỀU NĂC VỚI CƠ CHẾ LEO THANG

GIÁM SÁT CHÍNH CƠ CHẾ GIÁM SÁT

Chi tiết cuối cùng trong sơ đồ không thừa. Trên shared hosting, cron rất hay lặng lẽ ngừng chạy sau khi gia hạn gói hoặc đổi cấu hình PHP — và không ai biết cho tới lúc lỡ một mốc thời hạn. Phải có một cơ chế độc lập kiểm tra rằng job vẫn chạy, ví dụ một dịch vụ heartbeat miễn phí bên ngoài.

Luồng 5 — Thu phí dịch vụ và theo dõi công nợ

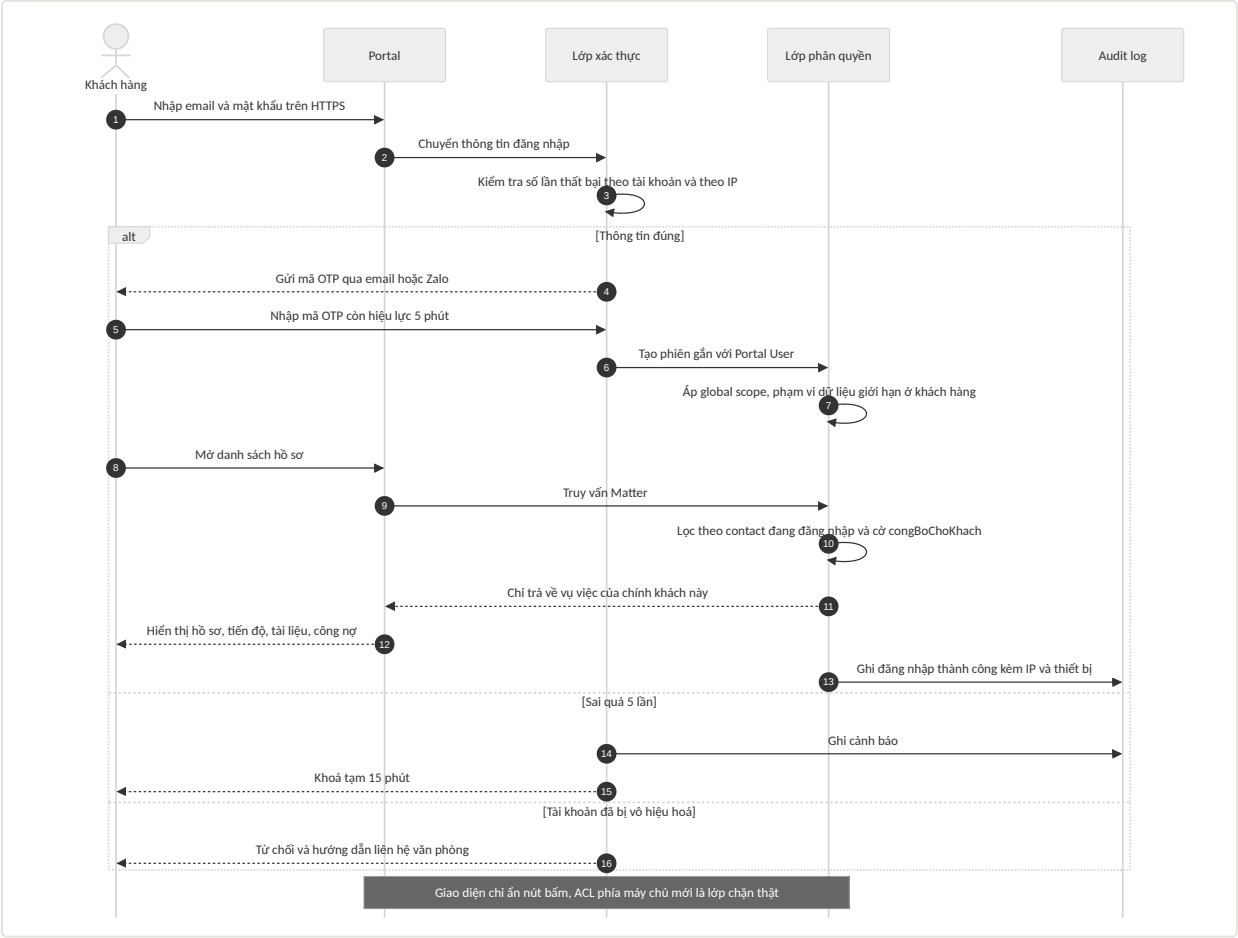


HÌNH 10 · CHU TRÌNH THU PHÍ, ĐỐI SOÁT BẰNG MÃ HỒ SƠ TRONG NỘI DUNG CHUYỂN KHOẢN

Đây là chỗ mã hồ sơ trả công. Vì mọi khoản chuyển khoản đều mang mã `VK-2026-DD-0147` trong nội dung, kế toán chỉ cần dán sao kê vào và hệ thống khớp gần như tự động. Giai đoạn sau có thể tích hợp API ngân hàng để bỏ hẳn bước thủ công, nhưng giai đoạn đầu đối chiếu tay là hoàn toàn chấp nhận được.

Luồng 6 — Đăng nhập portal và lớp kiểm soát truy cập

Nguyên tắc bất di bất dịch: **mọi kiểm tra quyền diễn ra ở phía máy chủ**. Giao diện chỉ ấn nút bấm; Policy và global scope phía máy chủ mới là thứ thực sự chặn dữ liệu. Không bao giờ dựa vào việc ẩn phần tử trên giao diện để bảo vệ thông tin.



HÌNH 11 · XÁC THỰC HAI LỚP VÀ PHẠM VI DỮ LIỆU CỦA PORTAL

Ma trận phân quyền

ĐỐI TƯỢNG DỮ LIỆU	LUẬT SƯ PHỤ TRÁCH	LUẬT SƯ KHÁC	TRỢ LÝ	KẾ TOÁN	KHÁCH HÀNG QUA PORTAL
Vụ việc	Sửa	Không thấy	Sửa hạn chế	Chỉ xem phần phí	Xem, nếu được công bố
Nhật ký tiến độ nội bộ	Sửa	Không thấy	Thêm	Không thấy	Không thấy
Nội dung công bố	Sửa	Không thấy	Thêm	Không thấy	Chỉ xem
Tài liệu vụ việc	Toàn quyền	Không thấy	Thêm, xem	Không thấy	Theo từng cờ quyền
Mốc thời hạn	Sửa	Không thấy	Xem	Không thấy	Xem mốc được công bố
Hợp đồng và công nợ	Xem	Không thấy	Không thấy	Sửa	Xem phần của mình
Yêu cầu từ khách	Sửa	Không thấy	Sửa	Không thấy	Tạo và xem
Danh bạ toàn công ty	Xem	Xem	Xem	Xem	Không thấy

Điểm then chốt là cột thứ ba: **luật sư không phụ trách thì không nhìn thấy vụ việc**. Đây không phải sự nghi kỵ nội bộ mà là yêu cầu nghiệp vụ — tránh xung đột lợi ích khi công ty nhận vụ việc có các bên đối lập, và thu hẹp thiệt hại nếu một tài khoản bị chiếm đoạt. Cài

Lộ trình triển khai

Chia bốn giai đoạn, mỗi giai đoạn kết thúc bằng một thứ dùng được thật. Không làm tất cả rồi mới bắt — cách đó gần như luôn dẫn tới một hệ thống đầy đủ tính năng mà không ai dùng.

GĐ 1 · 2–3 tuần Chạy được lõi CRM nội bộ

Dựng Laravel + Filament, cấu hình SMTP và cron, tạo bảng Vụ việc, Nhật ký tiến độ, Mốc thời hạn, Tài liệu, Các bên. Dựng vòng đời giai đoạn, phân quyền nội bộ và kiểm tra xung đột lợi ích. Nhập thử 20 hồ sơ đang chạy. Kết thúc giai đoạn: toàn văn phòng dùng CRM thay cho file Excel.

GĐ 2 · 2 tuần Bật portal khách hàng

Dựng panel portal với guard riêng và global scope giới hạn dữ liệu, tùy biến giao diện theo thương hiệu, cấu hình subdomain và SSL. Dựng kho tài liệu bốn nhóm với quy tắc mặc định ẩn, và danh mục hồ sơ chuẩn cho 3 loại vụ việc làm nhiều nhất. Mở cho 5 khách hàng thân thiết dùng thử trước, lấy phản hồi về cách diễn đạt giai đoạn. Kết thúc giai đoạn: khách tra cứu được tiến độ, thấy hồ sơ còn thiếu gì, và tải được tài liệu.

GĐ 3 · 2–3 tuần Tự động hoá và tích hợp

Viết Action và Job cho thông báo chuyển giai đoạn, nhắc hạn nhiều nấc, nối form website vào API, tích hợp Zalo ZNS. Kết thúc giai đoạn: luật sư chỉ đổi giai đoạn, phần còn lại tự chạy.

GĐ 4 · 2 tuần Tài chính và báo cáo

Hợp đồng, đợt thanh toán, công nợ, QR VietQR. Dashboard cho ban lãnh đạo: số vụ theo giai đoạn, vụ sắp đến hạn, công nợ quá hạn, nguồn khách theo bài viết. Kết thúc giai đoạn: họp giao ban nhìn vào màn hình CRM thay vì báo cáo tay.

ƯỚC TÍNH CHI PHÍ, CHỈ ĐỀ THAM KHẢO

KHOẢN MỤC	GHI CHÚ	TÍNH CHẤT
Laravel, Filament, các gói Spatie	Miễn phí, giấy phép MIT	Một lần
VPS hoặc nâng cấp hosting	Nếu shared hosting không đủ điều kiện ở mục 01	Hằng tháng
Tên miền và chứng chỉ	Hai subdomain cho CRM và portal	Hằng năm
Công triển khai và tùy biến	Khoảng 8–10 tuần công cho toàn bộ bốn giai đoạn	Một lần
Zalo ZNS	Tính theo tin gửi, cần duyệt template trước	Theo sử dụng
SSL, email tên miền, backup offsite	SSL có thể dùng Let's Encrypt miễn phí	Hằng năm

Con số cụ thể phụ thuộc vào việc anh thuê ngoài hay có người nội bộ làm, nên tài liệu này cố ý không đưa số tiền. Khi anh đã chọn được hướng nhân sự, có thể bóc tách chi tiết từng đầu việc để làm căn cứ báo giá.

13

Checklist bảo mật và tuân thủ

Dữ liệu trong hệ thống này đồng thời là **bí mật thông tin khách hàng theo Luật Luật sư** và **dữ liệu cá nhân theo Nghị định 13/2023/NĐ-CP** — trong nhiều vụ việc còn là dữ liệu cá nhân nhạy cảm. Mức độ cẩn trọng phải cao hơn một CRM bán hàng thông thường.

- ☐ **HTTPS bắt buộc trên cả ba subdomain**
kèm HSTS, chuyển hướng toàn bộ HTTP sang HTTPS.
- ☐ **Xác thực hai lớp**
bắt buộc cho mọi tài khoản nội bộ, khuyến nghị cho portal.
- ☐ **Chặn truy cập trực tiếp vào thư mục dữ liệu**
ở tầng web server, không chỉ dựa vào file cấu hình mặc định.
- ☐ **Phân quyền theo luật sư phụ trách**
, không để mặc định ai cũng xem được mọi hồ sơ.
- ☐ **Bật audit log**
cho đăng nhập, tải tài liệu, sửa vụ việc, và xuất dữ liệu.
- ☐ **Backup tự động hằng ngày**
gồm cả cơ sở dữ liệu và thư mục tài liệu, lưu ở nơi khác máy chủ, và
diễn tập phục hồi ít nhất một lần
— bản backup chưa từng phục hồi thử không phải là backup.
- ☐ **Chính sách xử lý dữ liệu cá nhân**
đăng trên portal, cùng điều khoản tương ứng bổ sung vào hợp đồng dịch vụ pháp lý.
- ☐ **Quy trình thu hồi quyền**
khi nhân sự nghỉ việc hoặc vụ việc kết thúc — vô hiệu hoá tài khoản portal sau khi hồ sơ đóng một khoảng thời gian đã định.

- ☐ **Cập nhật Laravel và các gói phụ thuộc định kỳ**
, chạy `composer audit` hằng tháng.

- ☐ **Giám sát cron bằng heartbeat bên ngoài**
, để cơ chế nhắc hạn không âm thầm chết.

Tài liệu kiến trúc soạn cho Công ty Luật Vũ Khang · 13.09.2026 ·
Nội dung kỹ thuật mang tính tham khảo triển khai; phân liên quan
đến nghĩa vụ tuân thủ dữ liệu cá nhân cần được rà soát lại theo
quy định hiện hành tại thời điểm vận hành.